

• CVE-2025-53770

ToolShell

SharePoint Zero-Day Angriff

9.8 CVSS Kritisch

Zero-Day RCE

Kein Login nötig

Prissner Elias • Doerr Daniel • Maendler Lukas

Was ist Microsoft SharePoint?

KONTEXT

Die Plattform hinter dem Angriff

Dokumentenverwaltung

Zentrale Ablage für Dateien und Dokumente aller Art im Unternehmen.

Zusammenarbeit

Teams arbeiten gemeinsam an Projekten, Seiten und Inhalten.

Intranet

Interne Webseiten und Portale für Unternehmen und Behörden.

SHAREPOINT ENTHÄLT HÄUFIG:

- Vertrauliche Dokumente
- Zugangsdaten und Passwörter
- Interne Kommunikation

Grundbegriffe einfach erklärt

GLOSSAR

Vier Begriffe, die heute oft fallen

CVE

COMMON VULNERABILITIES AND EXPOSURES

Eindeutige ID für jede bekannte Sicherheitslücke – weltweit einheitlicher Standard.

APT

ADVANCED PERSISTENT THREAT

Professionelle, oft staatlich finanzierte Hackergruppen mit langfristigen, gezielten Angriffszielen.

CVSS

SCORE 0 - 10

Misst die Gefährlichkeit einer Schwachstelle. 9.8 bedeutet: extrem kritisch, sofortiger Handlungsbedarf.

BSI

BUNDESAMT FÜR SICHERHEIT IN DER IT

Deutsche Behörde, die IT-Bedrohungen offiziell bewertet und Warnungen herausgibt.

Einordnung des Angriffs

PROFIL CVE-2025-53770 im Überblick

9.8

CVSS SCORE

K R I T I S C H

Höchste Bedrohungsstufe

CVE-KENNUNG

CVE-2025-53770

ANGRIFFSTYP

Zero-Day – keine Lösung zur Zeit des Angriffs

METHODE

Remote Code Execution (RCE)

AUTHENTIFIZIERUNG

NICHT erforderlich – kein Login nötig

ZIEL

Microsoft SharePoint Server

Offizieller Kontext

BSI Einschätzung & weltweite Auswirkungen

400+

bestätigte kompromittierte Systeme weltweit

In Eigenregie betriebene On-Premise SharePoint Server in zahlreichen Organisationen

- Massenangriffe weltweit – koordinierte globale Angriffswelle innerhalb kurzer Zeit
- Deutschland ebenfalls betroffen – Behörden und Unternehmen im Visier der Angreifer
- BSI stuft den Angriff **Orange** ein – Maßnahmen müssen unverzüglich ergriffen werden
- Angriffe erfolgten, **bevor** ein Sicherheitspatch verfügbar war (Zero-Day-Situation)

Die Angreifer

THREAT ACTORS

Staatlich geförderte APT-Gruppen

LT

Linen Typhoon

Chinesische APT-Gruppe, spezialisiert auf das Stehlen von geistigem Eigentum. Ziele: Behörden, Verteidigung, Menschenrechtsgruppen.

VT

Violet Typhoon

Chinesische APT-Gruppe, spezialisiert auf Spionage in den USA, Europa und Ostasien. Ziele: Behörden, Militär (ehem. Personal)...

S

Storm-2603

Wahrscheinlich in China ansässige Gruppe. Finanzielle und spionage-relevante Motivation.

MOTIVATION

Industriespionage

Datendiebstahl

Strategischer Zugriff

Langfristige Persistenz

Angriffsdiagramm

KILL CHAIN

Schritt-für-Schritt-Ablauf des ToolShell-Angriffs

1

Internet
ANGREIFER

2

/ToolPane.aspx
SHAREPOINT-ENDPUNKT

3

Deserialisierung
SCHWACHSTELLE

4

RCE
CODE-AUSFÜHRUNG

5

MachineKeys
SCHLÜSSEL GESTOHLEN

6

Persistenz
DAUERHAFTER ZUGRIFF

ViewState-Manipulation

Gefälschte Anfragen werden vom Server als legitim behandelt – kein Verdacht.

Datendiebstahl und Folge-Angriffe

Vollständige Kontrolle, Ransomware möglich, seitliche Netzwerk-Bewegung.

Verwendete Schwachstellen

ANATOMIE

Beide Schwachstellen aufgeschlüsselt

1

CVE-2025-53771

Authentifizierungs-Bypass

- Erlaubt es, die Authentifizierung zu umgehen
- Öffnet die Tür zum eigentlichen Exploit

2

CVE-2025-53770

Remote Code Execution

- Angreifer schickt manipulierte Daten (ViewState)
- Server führt fremden Code aus

Technischer Ablauf

VERGLEICH

Wie die Schwachstelle funktioniert

• Normaler Ablauf

- 1 Browser sendet ViewState an Server
- 2 Server prüft kryptografische Signatur
- 3 Anfrage ist gültig – wird sicher ausgeführt

• Angriffs-Ablauf

- 1 Angreifer kennt gestohlenen MachineKey
- 2 Erstellt gefälschten, signierten ViewState
- 3 Server prüft Signatur – als GÜLTIG erkannt
- 4 Schadcode wird unbemerkt ausgeführt

Auswirkungen des Angriffs

SCHADEN

Was Angreifer nach der Kompromittierung erreichen

Alle gespeicherten Dokumente

Betriebsgeheimnisse, HR-Akten, Verträge, Projektunterlagen

Zugangsdaten

Passwörter, Tokens, API-Schlüssel, Zertifikate

Interne Kommunikation

E-Mails, Teams-Chats, Projektpläne, Sitzungsprotokolle

Server-Konfiguration

Netzwerkstruktur, Firewallregeln, Systemeinstellungen

Warum besonders gefährlich?

RISIKO

Vier entscheidende Risikofaktoren

Kein Login nötig

Angriff aus jedem Internetzugang heraus möglich – keine gestohlenen Zugangsdaten erforderlich.

Schwer zu erkennen

Legitim aussehende Anfragen hinterlassen kaum Spuren in Standard-Protokollen.

Kombination mehrerer Lücken

Deserialisierung und ViewState-Manipulation macht Abwehr erheblich schwieriger.

Dauerhafter Verbleib

Angreifer können sich jahrelang im System halten, ohne entdeckt zu werden.

Gegenmaßnahmen

ACTION PLAN

Empfohlene Schritte zum Schutz

00

Antimalware Scan Interface (AMSI) und Microsoft Defender verwenden

Betreiber mit aktiviertem AMSI-Feature und Nutzer von Microsoft Defender für SharePoint Server sind vor einer Ausnutzung geschützt.

DRINGEND

01

Sicherheitsupdates einspielen

Microsofts Patch für CVE-2025-53770 sofort installieren. Automatische Updates aktivieren.

DRINGEND

02

MachineKeys rotieren

Alle bestehenden MachineKeys als kompromittiert betrachten und sofort erneuern.

DRINGEND

03

Logs analysieren

Alle Anfragen an /ToolPane.aspx rückwirkend prüfen. Anomalien und unbekannte Clients suchen.

04

Server-Monitoring einrichten

Echtzeit-Überwachung auf verdächtige Aktivitäten konfigurieren und Alarmer definieren.

Lessons Learned

TAKEAWAYS

Was wir aus diesem Angriff mitnehmen

L1 Keine öffentliche Erreichbarkeit

SharePoint-Server nicht direkt aus dem Internet erreichbar machen. VPN oder Zero-Trust-Zugang verwenden.

L2 Regelmäßige Sicherheitsupdates

Systeme müssen zeitnah gepatcht werden – jeder Tag Verzögerung erhöht das Risiko einer Kompromittierung.

L3 Aktives Monitoring

Ohne Überwachung bleiben Angriffe im Durchschnitt über 200 Tage unentdeckt.

L4 Schnelle Incident Response

Reaktionspläne müssen vorhanden und regelmäßig geübt sein – im Ernstfall zählt jede Stunde.

Fazit

ZUSAMMENFASSUNG

Was bleibt hängen

Sehr kritische Schwachstelle – einfacher Angriff, enormer Schaden

CVE-2025-53770 zeigt, wie eine einzige Sicherheitslücke zur vollständigen Kompromittierung führen kann – ohne Login, ohne Vorwarnung.

Staatliche Akteure nutzen Zero-Days gezielt für Spionage und langfristige Infiltration wichtiger Institutionen und Unternehmen.

Nur durch konsequente Updates, aktives Monitoring und schnelle Reaktion lassen sich solche Angriffe abwehren oder begrenzen.

Vielen Dank.

Fragen?

CVE-2025-53770 · CVSS 9.8 · Zero-Day RCE · Kein Login nötig · Staatliche Akteure

ToolShell - SharePoint Zero-Day Angriff · Prissner, Elias · Doerr, Daniel · Maendler, Lukas